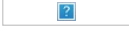


ZAP by Checkmarx Scanning Report

Generated with  ZAP on Mon 10 Mar 2025, at 08:25:49

ZAP Version: 2.16.0

ZAP by [Checkmarx](#)

Contents

- 1. [About this report](#)
 - 1. [Report parameters](#)
- 2. [Summaries](#)
 - 1. [Alert counts by risk and confidence](#)
 - 2. [Alert counts by site and risk](#)
 - 3. [Alert counts by alert type](#)
- 3. [Alerts](#)
 - 1. [Risk=High, Confidence=Medium \(4\)](#)
 - 2. [Risk=Medium, Confidence=High \(1\)](#)
 - 3. [Risk=Medium, Confidence=Medium \(5\)](#)
 - 4. [Risk=Medium, Confidence=Low \(1\)](#)
 - 5. [Risk=Low, Confidence=High \(3\)](#)
 - 6. [Risk=Low, Confidence=Medium \(8\)](#)
 - 7. [Risk=Informational, Confidence=High \(2\)](#)
 - 8. [Risk=Informational, Confidence=Medium \(7\)](#)
 - 9. [Risk=Informational, Confidence=Low \(4\)](#)
- 4. [Appendix](#)
 - 1. [Alert types](#)

About this report

Report parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://ajax.googleapis.com>
- <http://metasploitable3>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert counts by risk and confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence			
		User Confirmed	High	Medium	Low
Risk	High	0 (0.0%)	0 (0.0%)	4 (11.4%)	0 (0.0%)
	Medium	0 (0.0%)	1 (2.9%)	5 (14.3%)	1 (2.9%)
	Low	0 (0.0%)	3 (8.6%)	8 (22.9%)	0 (0.0%)
	Informational	0 (0.0%)	2 (5.7%)	7 (20.0%)	4 (11.4%)
	Total	0 (0.0%)	6 (17.1%)	24 (68.6%)	5 (14.3%)
		Total			
		0 (0.0%)	4 (11.4%)	13 (37.1%)	11 (31.4%)

Alert counts by site and risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Risk			
High	Medium	Low	Informational

		(= High)	(>= Medium)	(>= Low)	(>= Informational)
Site	http://ajax.googleapis.com	0 (0)	0 (0)	0 (0)	1 (1)
	http://metasploitable3	4 (4)	7 (11)	11 (22)	12 (34)

Alert counts by alert type

This table shows the number of alerts of each alert type, together with the alert type's risk level.
(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Cross Site Scripting (Persistent)	High	1 (2.9%)
Cross Site Scripting (Reflected)	High	1 (2.9%)
SQL Injection	High	2 (5.7%)
SQL Injection - SQLite	High	3 (8.6%)
Absence of Anti-CSRF Tokens	Medium	14 (40.0%)
Application Error Disclosure	Medium	2 (5.7%)
Content Security Policy (CSP) Header Not Set	Medium	491 (1,402.9%)
Cross-Domain Misconfiguration	Medium	20 (57.1%)
Directory Browsing	Medium	30 (85.7%)
Missing Anti-clickjacking Header	Medium	451 (1,288.6%)
Vulnerable JS Library	Medium	4 (11.4%)
Big Redirect Detected (Potential Sensitive Information Leak)	Low	1 (2.9%)
CSP: X-Content-Security-Policy	Low	11 (31.4%)
CSP: X-WebKit-CSP	Low	11 (31.4%)
Cookie No HttpOnly Flag	Low	2 (5.7%)
Cookie without SameSite Attribute	Low	289 (825.7%)
Cross-Domain JavaScript Source File Inclusion	Low	3 (8.6%)
Information Disclosure - Debug Error Messages	Low	1 (2.9%)
Private IP Disclosure	Low	1 (2.9%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	2000 (5,714.3%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	2099 (5,997.1%)
X-Content-Type-Options Header Missing	Low	2067 (5,905.7%)
Authentication Request Identified	Informational	26 (74.3%)
Content-Type Header Missing	Informational	1 (2.9%)
Cookie Poisoning	Informational	509 (1,454.3%)
GET for POST	Informational	3 (8.6%)
Information Disclosure - Sensitive Information in URL	Informational	1948 (5,565.7%)
Information Disclosure - Suspicious Comments	Informational	3327 (9,505.7%)
Loosely Scoped Cookie	Informational	920 (2,628.6%)
Modern Web Application	Informational	429 (1,225.7%)
Obsolete Content Security Policy (CSP) Header Found	Informational	11 (31.4%)
Retrieved from Cache	Informational	1 (2.9%)
Session Management Response Identified	Informational	755 (2,157.1%)
User Agent Fuzzer	Informational	702 (2,005.7%)
User Controllable HTML Element Attribute (Potential XSS)	Informational	877 (2,505.7%)
Total		35

Alerts

- Risk=High, Confidence=Medium (4)

1. **http://metasploitable3 (4)**
 1. [Cross Site Scripting \(Persistent\)](#) (1)
 - ▶ GET http://metasploitable3/chat/read_log.php?_=1741607868263
 2. [Cross Site Scripting \(Reflected\)](#) (1)
 - ▶ POST http://metasploitable3/payroll_app.php
 3. [SQL Injection](#) (1)
 - ▶ POST http://metasploitable3/payroll_app.php
 4. [SQL Injection - SQLite](#) (1)
 - ▶ POST http://metasploitable3/drupal/?q=user/register
2. **Risk=Medium, Confidence=High (1)**
 1. **http://metasploitable3 (1)**
 1. [Content Security Policy \(CSP\) Header Not Set](#) (1)
 - ▶ GET http://metasploitable3/sitemap.xml
3. **Risk=Medium, Confidence=Medium (5)**
 1. **http://metasploitable3 (5)**
 1. [Application Error Disclosure](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/Documentation.html
 2. [Cross-Domain Misconfiguration](#) (1)
 - ▶ GET http://metasploitable3/chat/
 3. [Directory Browsing](#) (1)
 - ▶ GET http://metasploitable3/drupal/misc/
 4. [Missing Anti-clickjacking Header](#) (1)
 - ▶ GET http://metasploitable3
 5. [Vulnerable JS Library](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/js/jquery/jquery-1.6.2.js?ts=1365422810
4. **Risk=Medium, Confidence=Low (1)**
 1. **http://metasploitable3 (1)**
 1. [Absence of Anti-CSRF Tokens](#) (1)
 - ▶ POST http://metasploitable3/chat/index.php
5. **Risk=Low, Confidence=High (3)**
 1. **http://metasploitable3 (3)**
 1. [CSP: X-Content-Security-Policy](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/setup/
 2. [CSP: X-WebKit-CSP](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/setup/
 3. [Server Leaks Version Information via "Server" HTTP Response Header Field](#) (1)
 - ▶ GET http://metasploitable3/sitemap.xml
6. **Risk=Low, Confidence=Medium (8)**
 1. **http://metasploitable3 (8)**
 1. [Big Redirect Detected \(Potential Sensitive Information Leak\)](#) (1)
 - ▶ POST http://metasploitable3/chat/index.php
 2. [Cookie No HttpOnly Flag](#) (1)
 - ▶ GET http://metasploitable3/chat/
 3. [Cookie without SameSite Attribute](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/
 4. [Cross-Domain JavaScript Source File Inclusion](#) (1)
 - ▶ GET http://metasploitable3/chat/index.php

5. [Information Disclosure - Debug Error Messages](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/Documentation.html
 6. [Private IP Disclosure](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/Documentation.html
 7. [Server Leaks Information via "X-Powered-By" HTTP Response Header Field\(s\)](#) (1)
 - ▶ GET http://metasploitable3/ payroll_app.php
 8. [X-Content-Type-Options Header Missing](#) (1)
 - ▶ GET http://metasploitable3
7. **Risk=Informational, Confidence=High (2)**
1. **http://metasploitable3 (2)**
 1. [GET for POST](#) (1)
 - ▶ GET http://metasploitable3/chat/post.php
 2. [Obsolete Content Security Policy \(CSP\) Header Found](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/setup/
8. **Risk=Informational, Confidence=Medium (7)**
1. **http://ajax.googleapis.com (1)**
 1. [Retrieved from Cache](#) (1)
 - ▶ GET http://ajax.googleapis.com/ajax/libs/jquery/1.3/jquery.min.js
 2. **http://metasploitable3 (6)**
 1. [Content-Type Header Missing](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/LICENSE
 2. [Information Disclosure - Sensitive Information in URL](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/url.php?collation_connection=utf8_general_ci&lang=en&token=a1de1b4eb6493ebf25ffe79e53e47048&url=http%3A%2F%2Fwww.phpmyadmin.net%2F
 3. [Information Disclosure - Suspicious Comments](#) (1)
 - ▶ GET http://metasploitable3/chat/
 4. [Modern Web Application](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/
 5. [Session Management Response Identified](#) (1)
 - ▶ GET http://metasploitable3/chat/
 6. [User Agent Fuzzer](#) (1)
 - ▶ POST http://metasploitable3/chat/index.php
9. **Risk=Informational, Confidence=Low (4)**
1. **http://metasploitable3 (4)**
 1. [Authentication Request Identified](#) (1)
 - ▶ POST http://metasploitable3/ payroll_app.php
 2. [Cookie Poisoning](#) (1)
 - ▶ POST http://metasploitable3/chat/index.php
 3. [Loosely Scoped Cookie](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/
 4. [User Controllable HTML Element Attribute \(Potential XSS\)](#) (1)
 - ▶ GET http://metasploitable3/phpmyadmin/url.php?collation_connection=utf8_general_ci&lang=en&token=a1de1b4eb6493ebf25ffe79e53e47048&url=http%3A%2F%2Fwww.phpmyadmin.net%2F

Appendix

Alert types

This section contains additional information on the types of alerts in the report.

1. Cross Site Scripting (Persistent)

Source raised by an active scanner ([Cross Site Scripting \(Persistent\)](#))

CWE ID [79](#)

WASC ID 8

Reference 1. <https://owasp.org/www-community/attacks/xss/>
2. <https://cwe.mitre.org/data/definitions/79.html>

2. Cross Site Scripting (Reflected)

Source raised by an active scanner ([Cross Site Scripting \(Reflected\)](#))

CWE ID [79](#)

WASC ID 8

Reference 1. <https://owasp.org/www-community/attacks/xss/>
2. <https://cwe.mitre.org/data/definitions/79.html>

3. SQL Injection

Source raised by an active scanner ([SQL Injection](#))

CWE ID [89](#)

WASC ID 19

Reference 1. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

4. SQL Injection - SQLite

Source raised by an active scanner ([SQL Injection - SQLite](#))

CWE ID [89](#)

WASC ID 19

Reference 1. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

5. Absence of Anti-CSRF Tokens

Source raised by a passive scanner ([Absence of Anti-CSRF Tokens](#))

CWE ID [352](#)

WASC ID 9

Reference 1. https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
2. <https://cwe.mitre.org/data/definitions/352.html>

6. Application Error Disclosure

Source raised by a passive scanner ([Application Error Disclosure](#))

CWE ID [200](#)

WASC ID 13

7. Content Security Policy (CSP) Header Not Set

Source raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))

CWE ID [693](#)

WASC ID 15

Reference 1. https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy
2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
3. <https://www.w3.org/TR/CSP/>
4. <https://w3c.github.io/webappsec-csp/>
5. <https://web.dev/articles/csp>
6. <https://caniuse.com/#feat=contentsecuritypolicy>
7. <https://content-security-policy.com/>

8. Cross-Domain Misconfiguration

Source raised by a passive scanner ([Cross-Domain Misconfiguration](#))

CWE ID [264](#)

WASC ID 14

Reference 1. https://vuln.catfortify.com/en/detail?id=desc.config.dotnet.html5_overly_permissive_cors_policy

9. Directory Browsing

Source raised by an active scanner ([Directory Browsing](#))

CWE ID [548](#)

WASC ID 48

Reference 1. <https://httpd.apache.org/docs/mod/core.html#options>

10. Missing Anti-clickjacking Header

Source raised by a passive scanner ([Anti-clickjacking Header](#))

CWE ID [1021](#)

WASC ID 15

Reference 1. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

11. Vulnerable JS Library

Source raised by a passive scanner ([Vulnerable JS Library \(Powered by Retire.js\)](#))

CWE ID [1395](#)

1. <https://nvd.nist.gov/vuln/detail/CVE-2012-6708>
2. <https://github.com/jquery/jquery/issues/2432>
3. <http://research.insecurelabs.org/jquery/test/>
4. <https://nvd.nist.gov/vuln/detail/CVE-2019-11358>
5. <https://github.com/advisories/GHSA-rmxg-73gg-4p98>
6. <https://bugs.jquery.com/ticket/11974>
7. <https://github.com/jquery/jquery.com/issues/162>
8. <https://nvd.nist.gov/vuln/detail/CVE-2020-7656>

- Reference**
9. <https://bugs.jquery.com/ticket/9521>
 10. <http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/>
 11. <http://bugs.jquery.com/ticket/11290>
 12. <https://research.insecurelabs.org/jquery/test/>
 13. <https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/>
 14. <https://nvd.nist.gov/vuln/detail/CVE-2015-9251>
 15. <https://github.com/advisories/GHSA-q4m3-2j7h-f7xw>
 16. <https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b>
 17. <https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/>
 18. <https://nvd.nist.gov/vuln/detail/CVE-2011-4969>
12. **Big Redirect Detected (Potential Sensitive Information Leak)**
- Source** raised by a passive scanner ([Big Redirect Detected \(Potential Sensitive Information Leak\)](#))
- CWE ID** [201](#)
- WASC ID** 13
13. **CSP: X-Content-Security-Policy**
- Source** raised by a passive scanner ([CSP](#))
- CWE ID** [693](#)
- WASC ID** 15
1. <https://www.w3.org/TR/CSP/>
 2. <https://caniuse.com/#search=content+security+policy>
- Reference**
3. <https://content-security-policy.com/>
 4. <https://github.com/HtmlUnit/htmlunit-csp>
 5. https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
14. **CSP: X-WebKit-CSP**
- Source** raised by a passive scanner ([CSP](#))
- CWE ID** [693](#)
- WASC ID** 15
1. <https://www.w3.org/TR/CSP/>
 2. <https://caniuse.com/#search=content+security+policy>
- Reference**
3. <https://content-security-policy.com/>
 4. <https://github.com/HtmlUnit/htmlunit-csp>
 5. https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
15. **Cookie No HttpOnly Flag**
- Source** raised by a passive scanner ([Cookie No HttpOnly Flag](#))
- CWE ID** [1004](#)
- WASC ID** 13
- Reference**
1. <https://owasp.org/www-community/HttpOnly>
16. **Cookie without SameSite Attribute**
- Source** raised by a passive scanner ([Cookie without SameSite Attribute](#))
- CWE ID** [1275](#)
- WASC ID** 13
- Reference**
1. <https://tools.ietf.org/html/draft-ietf-httpbis-cookie-same-site>
17. **Cross-Domain JavaScript Source File Inclusion**
- Source** raised by a passive scanner ([Cross-Domain JavaScript Source File Inclusion](#))
- CWE ID** [829](#)
- WASC ID** 15
18. **Information Disclosure - Debug Error Messages**
- Source** raised by a passive scanner ([Information Disclosure - Debug Error Messages](#))
- CWE ID** [200](#)
- WASC ID** 13
19. **Private IP Disclosure**
- Source** raised by a passive scanner ([Private IP Disclosure](#))
- CWE ID** [200](#)
- WASC ID** 13
- Reference**
1. <https://tools.ietf.org/html/rfc1918>
20. **Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)**
- Source** raised by a passive scanner ([Server Leaks Information via "X-Powered-By" HTTP Response Header Field\(s\)](#))
- CWE ID** [200](#)
- WASC ID** 13
- Reference**
1. https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
 2. <https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html>
21. **Server Leaks Version Information via "Server" HTTP Response Header Field**
- Source** raised by a passive scanner ([HTTP Server Response Header](#))
- CWE ID** [200](#)
- WASC ID** 13
- Reference**
1. <https://httpd.apache.org/docs/current/mod/core.html#servertokens>
 2. [https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552\(v=pandp.10\)](https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10))

3. <https://www.troyhunt.com/shhh-dont-let-your-response-headers/>

22. X-Content-Type-Options Header Missing

Source raised by a passive scanner ([X-Content-Type-Options Header Missing](#))
CWE ID [693](#)
WASC ID 15
Reference 1. [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))
2. <https://owasp.org/www-community/Security-Headers>

23. Authentication Request Identified

Source raised by a passive scanner ([Authentication Request Identified](#))
Reference 1. <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/>

24. Content-Type Header Missing

Source raised by a passive scanner ([Content-Type Header Missing](#))
CWE ID [345](#)
WASC ID 12
Reference 1. [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))

25. Cookie Poisoning

Source raised by a passive scanner ([Cookie Poisoning](#))
CWE ID [565](#)
WASC ID 20
Reference 1. https://en.wikipedia.org/wiki/HTTP_cookie
2. <https://cwe.mitre.org/data/definitions/565.html>

26. GET for POST

Source raised by an active scanner ([GET for POST](#))
CWE ID [16](#)
WASC ID 20

27. Information Disclosure - Sensitive Information in URL

Source raised by a passive scanner ([Information Disclosure - Sensitive Information in URL](#))
CWE ID [200](#)
WASC ID 13

28. Information Disclosure - Suspicious Comments

Source raised by a passive scanner ([Information Disclosure - Suspicious Comments](#))
CWE ID [200](#)
WASC ID 13

29. Loosely Scoped Cookie

Source raised by a passive scanner ([Loosely Scoped Cookie](#))
CWE ID [565](#)
WASC ID 15
Reference 1. <https://tools.ietf.org/html/rfc6265#section-4.1>
2. https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html
3. https://code.google.com/p/browsersec/wiki/Part2#Same-origin_policy_for_cookies

30. Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

31. Obsolete Content Security Policy (CSP) Header Found

Source raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))
CWE ID [693](#)
WASC ID 15
Reference 1. https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy
2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
3. <https://www.w3.org/TR/CSP/>
4. <https://w3c.github.io/webappsec-csp/>
5. <https://web.dev/articles/csp>
6. <https://caniuse.com/#feat=contentsecuritypolicy>
7. <https://content-security-policy.com/>

32. Retrieved from Cache

Source raised by a passive scanner ([Retrieved from Cache](#))
Reference 1. <https://tools.ietf.org/html/rfc7234>
2. <https://tools.ietf.org/html/rfc7231>
3. <https://www.rfc-editor.org/rfc/rfc9110.html>

33. Session Management Response Identified

Source raised by a passive scanner ([Session Management Response Identified](#))
Reference 1. <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id>

34. User Agent Fuzzer

Source raised by an active scanner ([User Agent Fuzzer](#))

Reference 1. <https://owasp.org/wstg>

35. User Controllable HTML Element Attribute (Potential XSS)

Source raised by a passive scanner ([User Controllable HTML Element Attribute \(Potential XSS\)](#))

CWE ID [20](#)

WASC ID 20

Reference 1. https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html